

Zakura Indexer gRPC Unauthenticated Resource Exhaustion Vulnerability Report

Summary

Indexer gRPC historically exposed plaintext unauthenticated streaming with weak global limits. In version 1.2.0, hard ceilings for retained connections and concurrent streams plus a TLS handshake timeout close the reviewed unbounded-growth path, while network access control remains necessary.

Mitigating Factors:

- The service exists only when the indexer feature is built and `indexer_listen_addr` is configured.
- Version 1.2.0 limits retained connections and concurrent HTTP/2 streams and applies a handshake timeout.
- Binding to loopback or a private authenticated gateway prevents direct anonymous Internet access.
- The streamed chain-tip and mempool information is primarily public data; the main concern is service availability.

Aggravating Factors:

- A plaintext externally reachable deployment still exposes the interface without transport authentication.
- gRPC reflection helps an unauthenticated client enumerate available methods.
- Long-lived subscriptions retain application and HTTP/2 state until they are cancelled or expire.
- Misconfigured or removed limits can reintroduce rapid multiplication of connections and streams.

Vulnerability Details:

Status, Product, and Version

- Record status: PUBLISHED
- Product and version: Zakura / zakurad / 1.2.0
- Weakness classification: CWE-306: Missing Authentication for Critical Function; CWE-770: Allocation of Resources Without Limits or Throttling

Cross-Validation Conclusion

The earlier architecture created an unauthenticated resource-exhaustion surface. The reviewed 1.2.0 boundaries prevent unbounded connection, stream, and handshake growth under the tested design, so the report should be treated as a fixed-risk verification record and a configuration-hardening requirement.

Trigger Conditions

- The indexer feature is enabled and `indexer_listen_addr` is configured.
- The endpoint is reachable from an untrusted client.
- A client attempts many TCP connections, many HTTP/2 streams, or stalled TLS handshakes.
- Risk increases if deployment overrides, bypasses, or removes the 1.2.0 resource ceilings.

Normal and Abnormal Behavior

Expected behavior in 1.2.0

The service retains no more than the configured global connection budget, limits concurrent streams per connection, and expires incomplete handshakes.

Unsafe regression

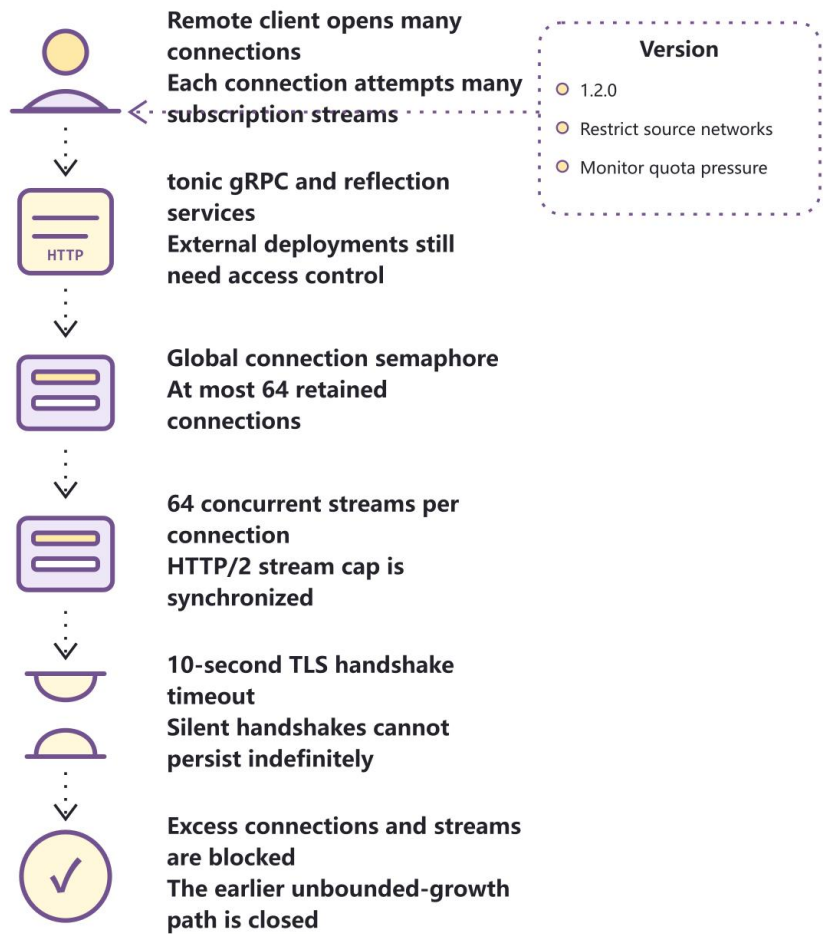
Connections, streams, or handshakes grow with attacker input without a corresponding hard upper bound, eventually displacing legitimate indexer clients.

Full Call Chain Diagram

The complete call chain is shown below. The dashed box states the deployment condition, version boundary, or evidence boundary that controls the conclusion.

Indexer gRPC Resource-Boundary Review

Version 1.2.0 applies hard limits to connections, streams, and handshakes



Technical Details:

Connection boundary

A global semaphore gates accepted connections before they can retain long-lived service state.

```
const MAX_CONNECTIONS: usize = 64;
let permit = connection_limit.clone().acquire_owned().await?;
serve_connection(socket, permit).await;
```

Stream boundary

The tonic and HTTP/2 configuration applies the same per-connection concurrent-stream ceiling.

```
Server::builder()
    .concurrency_limit_per_connection(64)
    .max_concurrent_streams(Some(64));
```

Handshake boundary

A fixed deadline prevents a silent TLS peer from retaining a connection slot forever.

```
let tls = tokio::time::timeout(
    Duration::from_secs(10),
    acceptor.accept(socket),
).await??;
```

Minimal Reproduction Logic (Isolated Test Environment Only)

On an isolated 1.2.0 node, attempt more than 64 retained connections, more than 64 concurrent streams on one connection, and a silent TLS handshake. Confirm that limits engage while a legitimate request remains serviceable.

```
assert(retained_connections <= 64)
assert(concurrent_streams_per_connection <= 64)
assert(silent_handshake_lifetime <= 10 seconds + scheduler_tolerance)
```

Security Impact

- With the 1.2.0 boundaries active, the reviewed unbounded-growth path is not expected to exhaust resources.
- If the endpoint is exposed without access control, anonymous clients can still consume the full configured quota and observe public stream data.
- A regression that removes any boundary could again impair legitimate indexer availability.

Long-Term Remediation

- Keep the 1.2.0 connection, stream, and handshake limits as non-optional security invariants.
- Place externally reachable gRPC behind TLS and authenticated access control.
- Restrict or disable reflection outside debugging and trusted management environments.
- Expose quota-rejection and saturation metrics for operational monitoring.

Recommended Regression Tests:

- Attempt 65 retained connections and verify that the extra connection is rejected or waits without additional retained service state.
- Attempt 65 concurrent streams on one connection and verify the documented cap.
- Hold a TLS handshake silent and verify expiration near 10 seconds.
- Verify that a legitimate ChainTipChange call succeeds below the boundary and after attacker connections are released.